

ENCUESTA INTEGRAL DE MADUREZ EN PRIVACIDAD

Marco LINDDUN / LIINE4DU — Edición 2025–2026

Kit de Diagnóstico para Organizaciones Españolas

"Porque la privacidad no se declara: se practica. Y el primer paso para practicarla es saber cuánto dista uno de hacerlo."

INSTRUCCIONES GENERALES

Destinatarios: Esta encuesta está diseñada para ser respondida por perfiles directivos y técnicos con responsabilidad sobre el tratamiento de datos personales: CISO, DPO, CTO, responsables de cumplimiento, directores de sistemas, responsables de negocio digital y comités de dirección.

Tiempo estimado: 45–90 minutos (puede aplicarse por módulos independientes).

Escala de respuesta: Salvo indicación expresa, cada ítem utiliza una escala Likert de 5 niveles combinada con opciones cualitativas descriptivas. El encuestado seleccionará la opción que *mejor* refleje la situación actual de su organización —sin aspiraciones, sin proyectos futuros, sin lo que "se está preparando" — sino lo que *existe y funciona hoy*.

Confidencialidad: Las respuestas son estrictamente confidenciales. Los resultados se tratarán de forma agregada para el cálculo del Índice de Madurez Global (IGM) y el análisis sectorial comparado.

Estructura: La encuesta se organiza en 10 módulos temáticos correspondientes a los 7 indicadores LINDDUN/LIINE4DU, más tres módulos transversales (Gobernanza, Tecnología e IA, y Continuidad).

MÓDULO 0 — PERFIL ORGANIZACIONAL

Este módulo permite contextualizar las respuestas y no afecta a la puntuación de madurez.

P0.1 — Sector de actividad

Marque el que mejor describe la actividad principal de su organización:

- ☐ Administración Pública (central, autonómica o local)
- ☐ Sanidad y ciencias de la vida
- ☐ Servicios financieros y seguros
- ☐ Tecnología, telecomunicaciones y medios
- ☐ Energía, agua e infraestructuras críticas
- ☐ Transporte y logística
- ☐ Educación e investigación
- ☐ Comercio minorista y e-commerce
- ☐ Industria y manufactura
- ☐ Consultoría y servicios profesionales
- ☐ Otro: _____

P0.2 — Tamaño organizacional

Número de empleados en plantilla:

- ☐ Menos de 50 (microempresa o PYME pequeña)
- ☐ 50–249 (PYME mediana)
- ☐ 250–999 (empresa mediana-grande)
- ☐ 1.000–4.999 (gran empresa)
- ☐ 5.000 o más (corporación)

P0.3 — Ámbito territorial de operaciones

¿En qué ámbitos territoriales opera principalmente su organización?

- ☐ Exclusivamente en España
- ☐ España + otros países de la Unión Europea
- ☐ España + países fuera de la UE (sin transferencias internacionales de datos)
- ☐ Operaciones globales con transferencias internacionales de datos
- ☐ Entidad que presta servicios al sector público español (proveedor/encargado)

P0.4 — Figura de Delegado de Protección de Datos (DPO)

¿Dispone su organización de DPO designado conforme al Art. 37 RGPD?

- ☐ Sí, DPO interno a tiempo completo
- ☐ Sí, DPO interno compartido con otras funciones
- ☐ Sí, DPO externo (servicio externalizado)
- ☐ No, pero tenemos previsto designarlo en los próximos 12 meses
- ☐ No disponemos de DPO ni está prevista su designación
- ☐ No tenemos certeza de si nuestra organización está obligada a designarlo

P0.5 — Rol del encuestado

¿Cuál es su función principal en relación con la protección de datos?

- ☐ CISO (Chief Information Security Officer)
- ☐ DPO / Delegado de Protección de Datos
- ☐ CTO / Director de Tecnología
- ☐ Director/a de Cumplimiento y/o Legal
- ☐ Responsable de Sistemas o Infraestructura
- ☐ Director/a General / CEO
- ☐ Responsable de área de negocio con tratamiento de datos
- ☐ Consultor/a externo/a de privacidad
- ☐ Otro: _____

P0.6 — Nivel de familiaridad con el marco LINDDUN

Antes de esta encuesta, ¿conocía el marco LINDDUN/LIINE4DU de modelado de amenazas de privacidad?

- ☐ Sí, lo aplico o he aplicado activamente en mi organización
- ☐ Sí, lo conozco pero no lo hemos implementado formalmente
- ☐ Había oído hablar de él pero no lo conozco en detalle
- ☐ No tenía conocimiento previo de LINDDUN
- ☐ Conozco marcos similares (STRIDE, PASTA) pero no LINDDUN específicamente

MÓDULO 1 — VINCULACIÓN (LINKING)

"Conectando los puntos que nadie debería conectar"

Indicador L (Linking): Riesgo de que datos aparentemente independientes sean asociados para aprender más sobre un individuo o grupo, incluso sin conocer su identidad directa.

P1.1 — Cartografía de flujos de datos y DFD

¿Dispone su organización de un Diagrama de Flujo de Datos (DFD) actualizado que recoja todos los flujos de datos personales entre sistemas internos y con terceros?

- ☐ A) No disponemos de ningún diagrama de flujos de datos. Los datos discurren por la organización como el Tajo: con naturalidad y sin cartografía conocida.
- ☐ B) Existe documentación fragmentaria de algunos sistemas, pero no hay un DFD unificado ni actualizado en los últimos 24 meses.
- ☐ C) Disponemos de un inventario de tratamientos (Registro de Actividades) pero no de un DFD que refleje los flujos entre sistemas y con encargados del tratamiento.
- ☐ D) Contamos con un DFD actualizado que cubre los sistemas principales, revisado en los últimos 12 meses, aunque las integraciones con APIs de terceros son un punto ciego reconocido.
- ☐ E) DFD completo, actualizado, con fronteras de confianza marcadas, revisión vinculada a cambios arquitectónicos y formato legible por herramientas de análisis automático.

P1.2 — Identificación de quasi-identificadores

¿Ha realizado su organización un análisis explícito de los quasi-identificadores (combinaciones de atributos que pueden singularizar a un individuo) en sus bases de datos?

- ☐ A) Los quasi-identificadores son un concepto con el que no trabajamos habitualmente. Nuestros datos están "anonimizados" porque hemos eliminado el nombre y el DNI.
- ☐ B) Conocemos el concepto pero no hemos realizado un análisis formal. Somos conscientes del riesgo teórico.
- ☐ C) Hemos identificado los quasi-identificadores en los conjuntos de datos que compartimos con terceros, pero no en el conjunto completo de tratamientos.
- ☐ D) Análisis de quasi-identificadores realizado para todos los tratamientos de alto riesgo, con estimación del riesgo de re-identificación (k-anonimato).
- ☐ E) Programa continuo de evaluación de re-identificación con k-anonimato ≥ 5 para datos ordinarios y k ≥ 10 para datos especiales, auditado anualmente.

P1.3 — Controles anti-vinculación entre sistemas

¿Qué medidas técnicas aplica su organización para limitar la vinculación de datos entre sistemas distintos?

(Marque todas las que apliquen)

- ☐ Pseudonimización con claves distintas por sistema/contexto
- ☐ Particionado de datos (data siloing) que impide cruce automatizado
- ☐ Privacidad diferencial en análisis agregados
- ☐ Tokenización de identificadores en flujos inter-sistemas
- ☐ Control de acceso basado en atributos (ABAC) que limita el acceso cruzado
- ☐ Ninguna de las anteriores de forma sistemática
- ☐ No aplica / No procesamos datos que requieran este nivel de protección

P1.4 — Perfilado y group profiling

¿Realiza su organización perfilado de individuos o grupos (incluyendo sistemas de recomendación, scoring, segmentación comportamental)?

- ☐ A) No realizamos perfilado de ningún tipo. Somos más de las relaciones humanas que de los algoritmos.
- ☐ B) Realizamos segmentación básica (marketing, CRM) sin análisis de privacidad específico sobre el proceso de perfilado.
- ☐ C) Realizamos perfilado y hemos identificado los riesgos asociados, pero no hemos implementado salvaguardas técnicas específicas más allá de la base legitimadora del consentimiento.
- ☐ D) El perfilado está documentado en la EIPD, con análisis de la amenaza Linking, y disponemos de mecanismos de oposición efectivos para los interesados.
- ☐ E) Perfilado sujeto a análisis LINDDUN completo, con técnicas de privacidad diferencial, auditorías de sesgo y mecanismo automatizado de opt-out con efecto inmediato.

P1.5 — Vinculación en sistemas de IA/ML

Si su organización utiliza sistemas de Machine Learning o IA, ¿ha evaluado el riesgo de inferencia de atributos no revelados a partir de las predicciones del modelo?

- ☐ A) No utilizamos ML/IA.
- ☐ B) Utilizamos ML/IA pero no hemos evaluado los riesgos de privacidad específicos de estos sistemas.
- ☐ C) Hemos realizado una evaluación general de riesgos de los sistemas ML/IA, pero sin análisis específico de la amenaza Linking/Inference.
- ☐ D) Los sistemas ML/IA han sido objeto de EIPD que incluye análisis de Linking, Identifying y ataques de inferencia de atributos.
- ☐ E) Evaluación completa con Attribute Inference Attack testing, Membership Inference Attack assessment y técnicas de ML privacidad-preservante (federated learning, differential privacy).

MÓDULO 2 — IDENTIFICABILIDAD (IDENTIFYING)

"Cuando el anonimato es solo una ilusión bien vestida"

Indicador I (Identifying): Riesgo de que un sujeto de datos pueda ser identificado dentro de un conjunto de sujetos, directa o indirectamente.

P2.1 — Análisis de k-anonimato en datos publicados o compartidos

¿Aplica su organización técnicas formales de anonimización (k-anonimato, l-diversidad, t-proximidad) antes de publicar o compartir conjuntos de datos?

- ☐ A) Publicamos o compartimos datos con identificadores directos eliminados. Consideramos eso suficiente.
- ☐ B) Aplicamos técnicas de anonimización básica (supresión, generalización) sin verificación formal del nivel de k-anonimato resultante.
- ☐ C) Calculamos el k-anonimato mínimo para los atributos quasi-identificadores identificados en los conjuntos compartidos, con $k \geq 3$.
- ☐ D) k-anonimato ≥ 5 verificado para datos ordinarios; l-diversidad aplicada para atributos sensibles; documentación del proceso disponible para auditores.
- ☐ E) Programa formal de anonimización con $k \geq 10$ para datos de salud o financieros, privacidad diferencial para publicaciones estadísticas y re-evaluación periódica ante avances en técnicas de re-identificación.

P2.2 — Gestión de datos biométricos

¿Trata su organización datos biométricos (reconocimiento facial, huellas, voz, iris)?

- ☐ A) Sí, los tratamos sin haber realizado una EIPD previa específica para ese tratamiento.
- ☐ B) Sí, con EIPD realizada pero que no incluye análisis de amenazas de Identificabilidad (LINDDUN) ni evaluación de proporcionalidad del sistema 1:N vs 1:1.
- ☐ C) Sí, con EIPD válida que incluye análisis de proporcionalidad, necesidad y alternativas menos intrusivas, así como consentimiento específico documentado.
- ☐ D) Sí, con EIPD completa, análisis LINDDUN de Identifying y Detecting, consulta previa a la AEPD (cuando ha sido requerida), y mecanismo de alternativa real no penalizadora para el interesado.
- ☐ E) No tratamos datos biométricos para identificación o verificación de identidad.

Nota: En referencia al caso AENA (AEPD, noviembre 2025), la ausencia de EIPD válida para datos biométricos supuso una multa de 10.043.002 €.

P2.3 — Ataques de re-identificación en sistemas de IA

¿Ha evaluado su organización la resistencia de sus modelos de IA frente a Membership Inference Attacks (MIA) o Attribute Inference Attacks (AIA)?

- ☐ A) No teníamos conocimiento de este tipo de ataques.
- ☐ B) Conocemos el riesgo teórico pero no hemos realizado evaluación práctica.
- ☐ C) Hemos leído la documentación de nuestros proveedores de IA sobre este tema pero no hemos realizado testing independiente.
- ☐ D) Hemos realizado evaluación de MIA/AIA en los modelos ML/IA de mayor riesgo, con documentación de resultados y aplicación de contramedidas.
- ☐ E) Testing periódico de MIA/AIA integrado en el ciclo de vida del modelo, con métricas de privacidad (ϵ -privacidad diferencial) documentadas y publicadas en la documentación técnica.

P2.4 — Identificación indirecta en sistemas de analítica web y marketing

¿Ha realizado su organización un análisis de los riesgos de identificación indirecta a través de cookies, fingerprinting o técnicas de seguimiento comportamental?

- ☐ A) Tenemos el banner de cookies con el "aceptar todo" bien visible y consideramos nuestra labor cumplida.
- ☐ B) Disponemos de CMP (Consent Management Platform) pero no hemos analizado los riesgos de identificabilidad más allá del consentimiento formal.
- ☐ C) Hemos realizado un análisis de los vectores de identificación indirecta (browser fingerprint, pixel tracking, cross-site tracking) y documentado los riesgos en el registro de actividades.
- ☐ D) Análisis completo de identificación indirecta con EIPD para los sistemas de analítica de mayor alcance, y despliegue de técnicas de mitigación (first-party data, server-side tagging, IP anonymization).
- ☐ E) Privacy-first analytics: sistema de medición sin cookies de terceros, sin identificadores persistentes de usuario, con auditoría anual de los vectores de identificación indirecta.

MÓDULO 3 — NO REPUDIO (NON-REPUDIATION)

"El rastro digital que no se puede borrar, o que se borra cuando no conviene"

Indicador NR (Non-repudiation): Riesgo de que un sujeto de datos sea incapaz de negar una afirmación, una acción o una presencia porque existen evidencias que lo vinculan —a veces más allá de lo razonable o de lo justo.

P3.1 — Política de retención y anonimización de logs

¿Dispone su organización de una política formal de retención de logs de auditoría y acceso que equilibre las necesidades de seguridad con los derechos de privacidad?

- ☐ A) Los logs se guardan hasta que el disco se llena o hasta que alguien pregunta. No hay política escrita.
- ☐ B) Existe política de retención (p.ej. "6 meses para logs de acceso") pero sin anonimización ni pseudonimización de los datos de usuario registrados.
- ☐ C) Política de retención documentada con plazos diferenciados por tipo de log (acceso, operación, seguridad), revisada en los últimos 12 meses.
- ☐ D) Política de retención + pseudonimización de identificadores de usuario en logs con rotación de claves, acceso restringido por roles y auditoría del acceso a los propios logs.
- ☐ E) Infraestructura de logging con privacidad integrada: anonimización dinámica, retención diferenciada por criticidad, soporte para derecho de supresión compatible con necesidades forenses, y documentación conforme al ENS.

P3.2 — Registros de interacción con sistemas de IA conversacional

Si su organización utiliza chatbots, asistentes virtuales o sistemas de IA conversacional, ¿cómo gestiona los registros de las conversaciones de los usuarios?

- ☐ A) No utilizamos IA conversacional.
- ☐ B) Las conversaciones se almacenan indefinidamente para "mejorar el modelo". Los usuarios no son informados específicamente de ello.
- ☐ C) Las conversaciones se almacenan con plazo de retención definido, los usuarios son informados en la política de privacidad, aunque con poca visibilidad.
- ☐ D) Retención limitada, información clara al usuario en el punto de recogida, mecanismo de supresión disponible a petición, y EIPD realizada para el sistema.
- ☐ E) Conversaciones procesadas en memoria de sesión sin persistencia por defecto, con opción explícita de almacenamiento opt-in, anonimización automática de datos personales identificados en el texto, y análisis LINDDUN completo del sistema.

P3.3 — Firma digital y no repudio en transacciones

¿Dispone de mecanismos para garantizar el no repudio en las transacciones digitales críticas (contratos electrónicos, consentimientos, operaciones financieras) sin comprometer la privacidad de los interesados?

- ☐ A) Las transacciones se registran en la base de datos con timestamp. Consideramos eso suficiente.
- ☐ B) Usamos firma electrónica avanzada (AdES) para contratos, pero sin análisis de los datos adicionales que genera el proceso (metadatos de firma, certificados de identidad).
- ☐ C) Firma electrónica con análisis de los metadatos generados, política de retención específica para evidencias de firma, y registro de actividades actualizado.
- ☐ D) Infraestructura PKI documentada, con análisis de los riesgos de no repudio vs. privacidad, diferenciando entre no repudio necesario (contratos) y no repudio innecesario (accesos ordinarios).
- ☐ E) Gestión diferenciada: no repudio fuerte para transacciones que lo requieren por ley, anonimización de logs para accesos que no lo requieren, y política documentada de "deniable authentication" para proteger la privacidad de usuarios legítimos.

P3.4 — Derecho al olvido y supresión de evidencias históricas

¿Ha gestionado su organización solicitudes de ejercicio del derecho de supresión (Art. 17 RGPD) que implicaban la eliminación de registros históricos o logs de auditoría?

- ☐ A) Hemos recibido solicitudes de este tipo y no hemos sabido cómo gestionarlas de forma coherente con los requisitos de seguridad.
- ☐ B) Las solicitudes de supresión se gestionan eliminando los datos de las bases de datos principales, pero los logs de auditoría, backups y sistemas secundarios no se abordan.
- ☐ C) Procedimiento documentado de supresión que incluye sistemas principales, pero con reconocimiento de que los backups y sistemas heredados representan una laguna operativa.
- ☐ D) Procedimiento integral de supresión que cubre sistemas principales, backups (con política de borrado seguro en rotación), encargados del tratamiento y logs de auditoría (con política de anonimización retroactiva).
- ☐ E) Sistema técnico de gestión de derechos con trazabilidad completa de la solicitud, evidencia de supresión en cada sistema afectado, y reconciliación con las obligaciones de retención obligatoria (fiscales, mercantiles, legales).

MÓDULO 4 — DETECCIÓN (DETECTING)

"Saber que alguien está, sin saber quién es: la incomodidad del panóptico invisible"

Indicador D (Detecting): Riesgo de deducir la implicación de un sujeto de datos en una actividad mediante observación, incluso sin poder identificarlo directamente.

P4.1 — Análisis de metadatos de comunicaciones

¿Dispone su organización de sistemas de monitorización de red que registren o analicen metadatos de comunicaciones de los empleados o usuarios (IPs, tiempos de conexión, volúmenes de tráfico, patrones de uso)?

- ☐ A) Monitorizamos el tráfico de red completo sin restricciones de privacidad y sin informar a los empleados.
- ☐ B) Tenemos sistemas de monitorización de red con información genérica a los empleados en el contrato o en el reglamento interno, pero sin análisis de los riesgos de detectabilidad.
- ☐ C) Monitorizamos con información adecuada a los empleados, política interna documentada y proporcionalidad declarada, aunque sin análisis formal de los riesgos LINDDUN-Detecting.
- ☐ D) Política de monitorización con análisis de proporcionalidad, minimización de metadatos retenidos, acceso restringido a análisis de tráfico individual, y EIPD realizada para los sistemas de monitorización.
- ☐ E) Monitorización de seguridad con privacidad integrada: análisis de tráfico agregado/anonimizado por defecto, acceso a datos de usuario individual solo ante incidente documentado, protocolo de escalada aprobado por el Comité de Ética/DPO.

P4.2 — Dispositivos IoT y detección de presencia

Si su organización despliega o gestiona dispositivos IoT (cámaras, sensores de presencia, wearables, contadores inteligentes, sistemas de control de acceso), ¿ha evaluado los riesgos de inferencia de comportamiento y presencia?

- ☐ A) Tenemos dispositivos IoT pero su gestión de privacidad no está integrada en nuestra estrategia de protección de datos.
- ☐ B) Los dispositivos IoT están inventariados pero no hemos realizado análisis de los patrones de datos que generan ni de sus implicaciones en materia de detección de presencia.
- ☐ C) Inventario de dispositivos IoT con clasificación por nivel de riesgo de privacidad y análisis básico de los datos que generan.
- ☐ D) Análisis LINDDUN-Detecting para todos los dispositivos IoT de alto riesgo, con medidas técnicas para minimizar la retención de patrones temporales y de comportamiento.
- ☐ E) Privacy-by-design en despliegues IoT: procesamiento local cuando es posible, datos federados sin transmisión de identificadores de dispositivo, revocación técnica de capacidad de tracking, y auditoría periódica del Detection Surface Index.

P4.3 — Sistemas de videovigilancia

¿Dispone su organización de sistemas de videovigilancia (incluyendo grabación, análisis de vídeo o reconocimiento de personas)?

- ☐ A) Sí, con grabación continua, sin señalización adecuada y sin política documentada de acceso o retención de imágenes.
- ☐ B) Sí, con señalización básica conforme al modelo AEPD, pero sin EIPD para los sistemas de videovigilancia ni análisis de los riesgos de detección e identificación.
- ☐ C) Sí, con EIPD, señalización adecuada, acceso restringido a imágenes, retención máxima de 30 días (art. 22 LOPDGDD) y registro de accesos a las grabaciones.
- ☐ D) Sí, con todo lo anterior más análisis específico de la amenaza Detecting (patrones de presencia) y Non-repudiation, diferenciando entre videovigilancia de seguridad y análisis comportamental.
- ☐ E) No disponemos de videovigilancia / La hemos reemplazado con sistemas menos intrusivos para los fines que perseguíamos.

P4.4 — Side-channel y canales laterales de información

¿Ha considerado su organización los riesgos de inferencia de información personal a través de canales laterales (consumo eléctrico, timing de respuestas, patrones de señal RF, análisis acústico)?

- ☐ A) Es la primera vez que escucho hablar de este tipo de riesgos en un contexto de privacidad.
- ☐ B) Conocemos los riesgos de canales laterales en el contexto de criptografía/seguridad, pero no los hemos conectado con los riesgos de privacidad de los interesados.
- ☐ C) Los hemos considerado en el contexto de instalaciones de alta seguridad (centros de datos, salas de servidores) pero no en el contexto de productos/servicios digitales orientados al consumidor.
- ☐ D) Análisis de canales laterales incluido en las EIPDs de sistemas de consumo o domótica que desplegamos, con medidas de mitigación documentadas.
- ☐ E) Evaluación sistemática de canales laterales para todos los sistemas de alto riesgo, con pruebas periódicas (penetration testing con perspectiva de privacidad) y documentación de hallazgos.

MÓDULO 5 — DIVULGACIÓN DE DATOS (DATA DISCLOSURE)

"Coleccionar datos es fácil; justificar por qué los tienes, ya es otra cosa"

Indicador DD (Data Disclosure): Riesgo de recopilar, almacenar, procesar o transferir datos personales en exceso respecto a la finalidad legítima del tratamiento.

P5.1 — Principio de minimización de datos (Art. 5.1.c RGPD)

¿Cómo evalúa su organización la proporcionalidad entre los datos recogidos y la finalidad declarada del tratamiento?

- ☐ A) Recogemos todo lo que podemos. El dato que no tienes hoy puede ser el dato que necesites mañana. La nube es infinita y la prudencia, costosa.
- ☐ B) Los formularios de recogida de datos se diseñaron cuando se montaron los sistemas y no han sido cuestionados desde entonces.
- ☐ C) Se aplica una revisión de minimización cuando se diseñan nuevos formularios o funcionalidades, aunque los sistemas heredados no han sido revisados con este criterio.
- ☐ D) Cada campo de cada formulario activo tiene justificación documentada vinculada a una finalidad específica, con revisión anual del Registro de Actividades y proceso de eliminación de campos innecesarios.
- ☐ E) Data minimization by design sistemático: privacy impact de cada nuevo campo antes de su implementación, proceso de sunset automático para campos sin uso en 6 meses, y auditoría anual de proporcionalidad.

P5.2 — Gestión de datos en sistemas de IA Generativa

Si su organización utiliza o desarrolla sistemas de IA Generativa (LLMs, sistemas de generación de contenido), ¿ha evaluado los riesgos de divulgación a través de representaciones intermedias (embeddings, gradientes, outputs)?

- ☐ A) No utilizamos IA Generativa.
- ☐ B) Utilizamos herramientas de IA Generativa (ChatGPT, Copilot, etc.) sin política específica sobre qué datos pueden introducirse en los prompts.
- ☐ C) Disponemos de política de uso aceptable de IA Generativa que prohíbe introducir datos personales en prompts de sistemas externos, pero sin controles técnicos que lo refuercen.
- ☐ D) Política de uso + controles técnicos (DLP aplicado a prompts, clasificación de datos antes del uso en IA), EIPD para los sistemas de IA Generativa desplegados internamente.
- ☐ E) Arquitectura de IA Generativa con privacidad integrada: anonimización de inputs antes de procesamiento, evaluación de riesgo de inversión de embeddings, federated learning cuando aplica, y análisis de los 6 CAMs del marco GenAI de KU Leuven/Huawei (2026).

P5.3 — Transferencias internacionales de datos

¿Realiza su organización transferencias internacionales de datos personales (fuera del EEE)?

- ☐ A) Sí, a través de servicios cloud de proveedores estadounidenses (AWS, Azure, Google Cloud) sin haber verificado los mecanismos de transferencia disponibles.
- ☐ B) Sí, con cláusulas contractuales tipo (SCC) en vigor, aunque sin análisis de la legislación del país de destino (Transfer Impact Assessment/TIA).
- ☐ C) Sí, con SCC + TIA documentado para los principales países de destino, y mención en el Registro de Actividades.
- ☐ D) Sí, con marco jurídico completo (SCC + TIA + medidas técnicas complementarias como cifrado extremo-a-extremo) y revisión anual o ante cambios regulatorios relevantes.
- ☐ E) No realizamos transferencias internacionales / Arquitectura cloud soberana o equivalente (datos en el EEE con garantías de no acceso desde terceros países).

P5.4 — Compartición de datos con encargados del tratamiento

¿Cómo gestiona su organización la supervisión de los encargados del tratamiento (proveedores que acceden a datos personales) respecto a la minimización de datos?

- ☐ A) Tenemos contratos de encargado del tratamiento (DPA) pero no supervisamos activamente si los encargados tratan más datos de los necesarios.
- ☐ B) DPAs firmados con los principales encargados, con cláusulas de minimización y limitación de finalidad, pero sin mecanismos de verificación periódica.
- ☐ C) DPAs con cláusulas de minimización + revisión anual formal de los principales encargados de alto riesgo + registro de incidentes relacionados con encargados.
- ☐ D) Programa de gestión de encargados con cuestionarios de cumplimiento, auditorías de los más críticos, y proceso de incidencias con plazos de respuesta definidos.
- ☐ E) Ecosistema de proveedores con privacy by design integrado en el proceso de selección (privacy due diligence), auditorías técnicas independientes para encargados de alto riesgo, y cláusulas de subencargamiento controladas.

P5.5 — Retención de datos y derecho al olvido técnico

¿Ha implementado su organización controles técnicos automatizados para la eliminación de datos personales una vez cumplido el plazo de retención?

- ☐ A) Los plazos de retención están definidos en la política, pero la eliminación se hace manualmente cuando alguien se acuerda.
- ☐ B) Hay procesos semiautomáticos de eliminación para las bases de datos principales, pero los backups, sistemas heredados y repositorios no estructurados (carpetas compartidas, email) quedan fuera.
- ☐ C) Eliminación automatizada para las bases de datos principales + proceso documentado para backups (eliminación en ciclo de rotación) + inventario de repositorios no estructurados con plan de revisión.
- ☐ D) Sistema de gestión del ciclo de vida del dato con alertas automáticas, proceso de eliminación verificado por el DPO, registro de eliminaciones como evidencia de cumplimiento.
- ☐ E) Data lifecycle management integrado en la arquitectura: etiquetado automático de datos con fecha de expiración, eliminación técnicamente verificable con certificado de destrucción para datos críticos.

MÓDULO 6 — DESCONOCIMIENTO E IMPOSIBILIDAD DE INTERVENCIÓN (UNAWARENESS)

"Informar no es colgar un PDF de 47 páginas en el footer de la web"

Indicador U (Unawareness/Unintervenability): Riesgo de informar, involucrar o empoderar a los interesados de forma insuficiente respecto al tratamiento de sus datos personales.

P6.1 — Calidad y accesibilidad de la información al interesado

¿Cómo evaluaría la calidad de la información que su organización proporciona a los interesados sobre el tratamiento de sus datos (Arts. 13–14 RGPD)?

- ☐ A) Disponemos de política de privacidad redactada por el área legal, con lenguaje técnico-jurídico, accesible desde el footer de la web en letra de tamaño microscópico. Cumplimos. O eso creemos.
- ☐ B) La política de privacidad es completa desde el punto de vista normativo, pero no hemos evaluado si los interesados la comprenden realmente.
- ☐ C) Política de privacidad en lenguaje comprensible, con información en capas (resumen + detalle), revisada por el DPO, aunque sin test de comprensión con usuarios reales.
- ☐ D) Información en capas con resumen ejecutivo accesible, lenguaje B2 validado por test de comprensión, versiones específicas por tipo de interesado (empleados, clientes, menores) y actualización ante cambios relevantes.
- ☐ E) Sistema de información dinámica: avisos contextuales en el momento del tratamiento, notificaciones proactivas ante cambios de finalidad, dashboard de privacidad con visibilidad del tratamiento en tiempo real para el interesado.

P6.2 — Gestión del consentimiento

¿Cómo gestiona su organización la recogida, el registro y la revocación del consentimiento (cuando el consentimiento es la base legitimadora del tratamiento)?

- ☐ A) Consentimiento recogido mediante casillas pre-marcadas o consentimiento implícito por uso del servicio. Desconocemos si esto sigue siendo válido, aunque esperamos que sí.
- ☐ B) Consentimiento afirmativo documentado, pero el proceso de revocación es tedioso o requiere contacto con atención al cliente.
- ☐ C) Consentimiento afirmativo + revocación tan fácil como el otorgamiento (Art. 7.3 RGPD), con registro de la fecha y método de otorgamiento/revocación.
- ☐ D) Sistema de gestión del consentimiento (CMP) con granularidad por finalidad, registro auditable de cambios, revocación inmediata con efecto técnico verificable, y revisión periódica de la validez del consentimiento obtenido.
- ☐ E) Privacy preference center completo: dashboard de consentimientos gestionado por el propio interesado, historial de cambios, notificación proactiva ante expiración o cambios en las condiciones, integrado en la arquitectura del sistema mediante Privacy APIs.

P6.3 — Ejercicio de derechos ARCO+ (Acceso, Rectificación, Supresión, Portabilidad, Limitación, Oposición)

¿Cuál es el tiempo medio de respuesta real de su organización ante solicitudes de ejercicio de derechos de los interesados?

- ☐ A) No llevamos registro sistemático de solicitudes de ejercicio de derechos. Cuando llegan, se gestionan caso por caso con el plazo que se puede.
- ☐ B) Existe un canal definido pero el proceso es manual, dependiente de personas clave, y el plazo de respuesta supera ocasionalmente el mes legal.
- ☐ C) Canal definido + proceso documentado con responsables asignados + respuesta media dentro del plazo de 30 días + registro de solicitudes y respuestas.
- ☐ D) Todo lo anterior + cuadro de mando de solicitudes con alertas de vencimiento + tasa de cumplimiento en plazo > 95% + revisión trimestral por el DPO.
- ☐ E) Portal de autogestión de derechos: el interesado puede ejercer acceso, rectificación y portabilidad de forma autónoma 24/7, con efectividad técnica inmediata para rectificación y respuesta garantizada en < 15 días para supresión.

P6.4 — Información sobre decisiones automatizadas

¿Utiliza su organización decisiones total o parcialmente automatizadas con efectos significativos sobre las personas (scoring crediticio, selección de personal, determinación de precios personalizados, etc.)?

- ☐ A) Sí, sin informar al interesado de la existencia de la decisión automatizada ni de su lógica, ni ofrecerle el derecho a intervención humana.
- ☐ B) Sí, con mención genérica en la política de privacidad, pero sin información específica sobre la lógica aplicada, los datos utilizados ni el derecho a impugnación.
- ☐ C) Sí, con información significativa sobre la lógica, la importancia y las consecuencias previsibles (Art. 22.3 RGPD), y mecanismo documentado para solicitar intervención humana.
- ☐ D) Sí, con EIPD específica para el sistema de decisión automatizada, información explícita y comprensible sobre la lógica, mecanismo efectivo de impugnación con plazos de respuesta definidos, y auditoría periódica de sesgo.
- ☐ E) No utilizamos decisiones automatizadas con efectos significativos / Las hemos sustituido por procesos con supervisión humana significativa.

P6.5 — Alfabetización en privacidad de la organización

¿Dispone su organización de programas de formación en protección de datos y privacidad para el personal?

- ☐ A) La formación consiste en el email de bienvenida que menciona que "debemos respetar la privacidad". Nadie lo ha leído hasta el final.
- ☐ B) Formación inicial para nuevas incorporaciones y formación anual genérica sobre RGPD, sin diferenciación por rol o nivel de riesgo del tratamiento.
- ☐ C) Formación diferenciada por perfiles (general, técnica, DPO/Legal), con test de comprensión, registro de asistencia y actualización anual.
- ☐ D) Programa de cultura de privacidad: formación continua, ejercicios de concienciación (phishing simulado con datos personales, juegos de rol), métricas de madurez de cultura y revisión por el Comité de Dirección.
- ☐ E) Privacy Champions Network: red de embajadores de privacidad por departamento, formación avanzada para técnicos en LINDDUN/LIINE4DU, métricas de Privacy Culture Index y reporte anual al Consejo de Administración.

MÓDULO 7 — INCUMPLIMIENTO (NON-COMPLIANCE)

"El RGPD no es una lista de la compra: es un sistema de principios con consecuencias"

Indicador NC (Non-compliance): Riesgo de desviarse de las mejores prácticas, estándares y legislación en materia de seguridad y protección de datos. En LIINE4DU, esta categoría queda absorbida en Data Breach y Deception para mayor precisión normativa.

P7.1 — Análisis de brecha regulatoria

¿Ha realizado su organización un análisis formal de brecha (gap analysis) respecto a los requisitos del RGPD, AI Act y NIS2 en los últimos 12 meses?

- ☐ A) No hemos realizado análisis de brecha formal. Asumimos que cumplimos porque no nos han sancionado todavía.
- ☐ B) Realizamos una adecuación al RGPD en 2018 y no hemos actualizado el análisis desde entonces. Los tiempos han cambiado, pero la documentación, no tanto.
- ☐ C) Gap analysis del RGPD realizado en los últimos 24 meses, con plan de acción en curso, aunque sin análisis específico de AI Act ni NIS2.
- ☐ D) Gap analysis multi-normativo (RGPD + AI Act + NIS2 + ENS si aplica) realizado en los últimos 12 meses, con plan de remediación priorizado y seguimiento trimestral.
- ☐ E) Programa de cumplimiento continuo: marco integrado RGPD/AI Act/NIS2/ENS con Compliance Gap Index (CGI) calculado por sistema, cuadro de mando de cumplimiento actualizado mensualmente y revisión semestral por el Consejo de Administración.

P7.2 — Evaluaciones de Impacto en Protección de Datos (EIPD/DPIA)

¿Cuál es el proceso de su organización para determinar cuándo es obligatoria una EIPD y para realizarla conforme al Art. 35 RGPD?

- ☐ A) Realizamos EIPDs cuando la AEPD nos lo pide o cuando la prensa publica algo alarmante sobre el sector.
- ☐ B) Tenemos criterios para determinar cuándo es obligatoria la EIPD (lista de tratamientos de alto riesgo) pero el proceso de realización es informal y no siempre documentado.
- ☐ C) Proceso documentado de cribado (screening) para nuevos tratamientos + EIPDs realizadas conforme a la metodología de la AEPD para los tratamientos identificados como de alto riesgo.
- ☐ D) Todo lo anterior + revisión periódica de EIPDs existentes (ante cambios en el tratamiento) + integración del análisis de amenazas LINDDUN/LIINE4DU en la sección de identificación de riesgos de la EIPD.
- ☐ E) Privacy Engineering integrada en el SDLC (Software Development Lifecycle): análisis LINDDUN en fase de diseño como prerequisite para el inicio del desarrollo, EIPD como artefacto de entrega del proyecto, y revisión post-implantación a los 6 meses.

P7.3 — Cumplimiento del AI Act (desde febrero 2025)

¿Ha evaluado su organización el impacto del Reglamento de IA Europeo en sus sistemas de IA desplegados o en desarrollo?

- ☐ A) El AI Act es algo que "nos afectará en el futuro". Hemos delegado el seguimiento en "alguien que está mirando eso".
- ☐ B) Hemos leído el AI Act pero no hemos realizado una clasificación formal de nuestros sistemas de IA por nivel de riesgo (prohibido, alto riesgo, limitado riesgo, mínimo riesgo).
- ☐ C) Clasificación de sistemas de IA por nivel de riesgo realizada, con identificación de los de alto riesgo y plan de cumplimiento en curso.
- ☐ D) Clasificación completa + sistema de gestión de riesgos conforme al Art. 9 AI Act para los sistemas de alto riesgo + registro en la UE cuando sea requerido + designación de responsable de cumplimiento AI Act.
- ☐ E) Programa de AI Governance: comité de ética de IA, evaluaciones de conformidad, documentación técnica conforme al Anexo IV AI Act, evaluación de derechos fundamentales (Art. 27 AI Act) y uso de las guías AESIA 2025 como marco de referencia.

P7.4 — Gestión de brechas de datos (Art. 33-34 RGPD)

¿Dispone su organización de un procedimiento documentado para la detección, análisis, notificación y comunicación de brechas de datos personales?

- ☐ A) En caso de brecha, entraríamos en modo crisis ad-hoc. El procedimiento existe en la cabeza de algunas personas clave.
- ☐ B) Procedimiento documentado para la notificación a la AEPD (plazo 72 horas), pero sin criterios claros para determinar si la brecha requiere comunicación a los interesados.
- ☐ C) Procedimiento completo: detección, análisis de gravedad (con criterios del GT29), notificación a la AEPD en plazo, comunicación a afectados cuando procede, y registro de brechas.
- ☐ D) Todo lo anterior + simulacros anuales de respuesta a brechas + indicadores de tiempo de detección (MTTD) y tiempo de contención (MTTC) + revisión post-incidente documentada.
- ☐ E) Centro de operaciones de privacidad (Privacy SOC): detección automatizada de brechas potenciales, playbooks de respuesta por tipo de incidente, integración con el SIEM de seguridad, métricas de MTTD/MTTC/MTTR publicadas internamente y reportadas al Consejo.

P7.5 — Relación con la AEPD y autoridades de control

¿Cómo caracterizaría la relación de su organización con la Agencia Española de Protección de Datos?

- ☐ A) Reactiva y ansiógena: solo interactuamos con la AEPD cuando recibimos una reclamación o inspección.
- ☐ B) Reactiva pero ordenada: tenemos proceso para responder a requerimientos de la AEPD, aunque no hay interacción proactiva.
- ☐ C) Neutra y profesional: cumplimos los requerimientos en plazo, consultamos la web de la AEPD para orientación y seguimos sus guías y circulares.
- ☐ D) Proactiva: participamos en consultas públicas de la AEPD, utilizamos el servicio de consultas previas cuando tenemos dudas sobre tratamientos complejos, y formamos parte de asociaciones sectoriales que interactúan con la AEPD.
- ☐ E) Colaborativa: participamos en programas de la AEPD (Laboratorio de Privacidad, grupos de trabajo), contribuimos con documentación de casos de uso a iniciativas como LIINE4DU, y mantenemos relación directa entre el DPO y la AEPD en el marco del Art. 38.4 RGPD.

MÓDULO 8 — INEXACTITUD Y EXCLUSIÓN (LIINE4DU)

"El dato incorrecto que toma decisiones por usted: el fantasma en la máquina"

Indicadores específicos de LIINE4DU (Agencia Española de Protección de Datos, 2024): Inaccuracy (inexactitud de datos) y Exclusion (obstaculización de la participación del interesado).

P8.1 — Integridad y exactitud de los datos (Inaccuracy)

¿Dispone su organización de controles para garantizar que los datos personales son exactos y están actualizados (Art. 5.1.d RGPD)?

- ☐ A) Los datos se almacenan cuando se recogen y se usan mientras sean necesarios. La exactitud es responsabilidad del interesado, que debería avisarnos si cambian.
- ☐ B) Existe un proceso de actualización reactiva (cuando el interesado lo solicita), pero no hay controles proactivos de calidad del dato.
- ☐ C) Proceso de actualización reactiva + revisión periódica de los datos más críticos (p.ej., datos de contacto de clientes activos) + control de calidad en la ingesta de nuevos datos.
- ☐ D) Programa de calidad del dato: métricas de exactitud por dataset, alertas automáticas ante datos sospechosamente desactualizados, proceso de verificación activa para datos con implicaciones decisivas (scoring, elegibilidad).
- ☐ E) Data Quality Management integrado: validación en origen, detección de inconsistencias cruzadas entre sistemas, proceso de corrección con notificación automática al interesado y registro de la corrección como evidencia de cumplimiento del Art. 5.1.d.

P8.2 — Sesgo en sistemas de decisión y datos de entrenamiento (Inaccuracy en IA)

Si su organización utiliza sistemas de IA para tomar o apoyar decisiones sobre personas, ¿ha evaluado el sesgo en los datos de entrenamiento y en los outputs del modelo?

- ☐ A) No utilizamos IA para decisiones sobre personas.
- ☐ B) Utilizamos IA para decisiones sobre personas pero no hemos realizado evaluación de sesgo específica.
- ☐ C) Evaluación de sesgo realizada en la fase de desarrollo del modelo, con documentación de los datasets de entrenamiento y sus posibles limitaciones.
- ☐ D) Evaluación de sesgo en desarrollo + monitorización periódica de drift y sesgo en producción + proceso de recalibración cuando se detectan disparidades injustificadas por grupos protegidos.
- ☐ E) Programa de fairness and accountability: auditoría independiente anual de sesgo, informe de impacto en derechos fundamentales (Art. 27 AI Act), participación de grupos afectados en la validación del modelo.

P8.3 — Exclusión y barreras al ejercicio de derechos (Exclusion)

¿Ha identificado su organización barreras que dificulten la participación física o digital de determinados colectivos en el ejercicio de sus derechos?

- ☐ A) Nunca lo hemos analizado. Si alguien no puede ejercer sus derechos, es un problema de alfabetización digital del interesado, no nuestro.
- ☐ B) Disponemos de canal web para el ejercicio de derechos, aunque no hemos evaluado su accesibilidad para personas mayores, con discapacidad o sin competencias digitales.
- ☐ C) Canal web + canal alternativo (correo postal, presencial) para el ejercicio de derechos, con información sobre ambos en la política de privacidad.
- ☐ D) Análisis de accesibilidad del canal de ejercicio de derechos (WCAG 2.1), múltiples canales disponibles, información en formatos alternativos (lectura fácil, audio), y revisión por el DPO.
- ☐ E) Inclusión por diseño: canal de derechos con accesibilidad AA certificada, soporte en múltiples idiomas (incluyendo lenguas cooficiales), asistente humano disponible para personas con dificultades y evaluación periódica de barreras de exclusión.

MÓDULO 9 — GOBERNANZA Y MADUREZ ORGANIZACIONAL

"Una organización con buena gobernanza de privacidad no espera al inspector para ordenar su casa"

P9.1 — Integración de la privacidad en la estrategia corporativa

¿Hasta qué punto está la protección de datos integrada en la estrategia corporativa de su organización?

- ☐ A) La protección de datos es una función legal/compliance, aislada del negocio. Es un coste regulatorio, no una ventaja competitiva.
- ☐ B) La protección de datos tiene visibilidad a nivel de Comité de Dirección, pero como tema reactivo (cuando hay incidentes o cambios regulatorios).
- ☐ C) El DPO reporta regularmente al Comité de Dirección, la privacidad está en el mapa de riesgos corporativo y hay KPIs de protección de datos en el cuadro de mando.
- ☐ D) Privacy como valor de marca: la protección de datos forma parte del posicionamiento competitivo, con comunicación externa y programa de certificación (ISO 27701, ENS, sello de privacidad).
- ☐ E) Privacy-as-a-business-driver: diferenciación competitiva basada en privacidad, transparencia radical con interesados, programas de privacy-enhancing products y reporting público anual de indicadores de privacidad.

P9.2 — Presupuesto asignado a privacidad y protección de datos

¿Dispone su organización de un presupuesto específico y separado para privacidad y protección de datos (distinto del presupuesto de ciberseguridad general)?

- ☐ A) No existe presupuesto específico. Los gastos de privacidad se justifican caso por caso cuando surge un problema.
- ☐ B) Existe una partida presupuestaria de cumplimiento que cubre tanto seguridad como privacidad, sin desagregación.
- ☐ C) Presupuesto específico de privacidad para gastos directos (DPO, herramientas, formación) aunque no para inversión en Privacy by Design en proyectos.
- ☐ D) Presupuesto de privacidad diferenciado + partida en los proyectos tecnológicos para análisis LINDDUN y EIPD + presupuesto de formación y cultura de privacidad.
- ☐ E) Modelo de inversión en privacidad con ROI calculado: coste de no cumplimiento (CNI) vs. coste de cumplimiento, con reporting al Consejo de Administración del retorno de la inversión en privacidad.

P9.3 — Métricas y KPIs de privacidad

¿Mide su organización su desempeño en privacidad mediante indicadores cuantificables?

- ☐ A) No disponemos de métricas específicas de privacidad. "Sin noticias, buenas noticias."
- ☐ B) Medimos el número de reclamaciones ante la AEPD y el número de brechas notificadas. Es suficiente para saber si algo va muy mal.
- ☐ C) KPIs básicos: tasa de respuesta a solicitudes de derechos en plazo, número de EIPDs realizadas, tasa de formación completada, número de brechas notificadas.
- ☐ D) Cuadro de mando de privacidad: KPIs cuantitativos y cualitativos por indicador LINDDUN, Privacy Maturity Score, tiempo medio de respuesta a derechos, Compliance Gap Index por normativa, reportado trimestralmente al Comité de Dirección.
- ☐ E) Privacy Observability: Índice de Madurez Global (IGM) calculado conforme a estándares (ISMS Forum Indicador de Madurez RGPD), benchmarking sectorial, Privacy Risk Score por tratamiento, y reporting público anual de indicadores clave.

MÓDULO 10 — TECNOLOGÍA, IA AGÉNTICA Y RESILIENCIA DIGITAL

"La IA no pide permiso: la gobernanza de la IA sí debería hacerlo"

P10.1 — Inventario y clasificación de sistemas de IA

¿Dispone su organización de un inventario actualizado de todos los sistemas de IA en uso (incluyendo los proporcionados por terceros) con clasificación por nivel de riesgo conforme al AI Act?

- ☐ A) No disponemos de inventario de sistemas de IA. Los equipos los adoptan de forma autónoma según sus necesidades.
- ☐ B) Inventario parcial (solo los sistemas de IA desarrollados internamente), sin clasificación formal por nivel de riesgo.
- ☐ C) Inventario de sistemas de IA internos y principales proveedores externos, con clasificación preliminar por nivel de riesgo (sin validación jurídica completa).
- ☐ D) Inventario completo con clasificación jurídica validada por el equipo legal/DPO, documentación técnica de los sistemas de alto riesgo, y proceso de alta de nuevos sistemas con análisis obligatorio.
- ☐ E) AI Registry corporativo: inventario vivo con control de versiones, análisis de impacto en derechos fundamentales para sistemas de alto riesgo, proceso de aprobación ética previa al despliegue, y auditoría anual por tercero independiente.

P10.2 — IA Agéntica y sistemas autónomos

¿Utiliza o está desarrollando su organización sistemas de IA agéntica (agentes autónomos capaces de tomar decisiones y actuar sin supervisión humana constante)?

- ☐ A) Sí, estamos desplegando agentes autónomos sin análisis específico de los riesgos de privacidad que su autonomía introduce.
- ☐ B) Estamos explorando la IA agéntica pero no hemos formalizado el marco de gobernanza específico para sistemas autónomos.
- ☐ C) Tenemos un marco de gobernanza para IA agéntica en desarrollo, con principios de supervisión humana y límites de autonomía definidos.
- ☐ D) Marco de gobernanza operativo para IA agéntica: principios de Human-in-the-Loop (HITL) o Human-on-the-Loop (HOTL) definidos, análisis de privacidad de los datos a los que el agente accede de forma autónoma, y trazabilidad de decisiones del agente.
- ☐ E) Arquitectura de IA agéntica con privacidad integrada: análisis de los 6 CAMs del marco GenAI (KU Leuven/Huawei 2026), mecanismos de explicabilidad de decisiones del agente, audit trail inmutable de acciones del agente, y evaluación periódica de deriva de comportamiento.
- ☐ F) No utilizamos ni tenemos previsto utilizar IA agéntica.

P10.3 — Resiliencia digital y continuidad de negocio con perspectiva de privacidad

¿Integra su Plan de Continuidad de Negocio (BCP/PCN) el impacto de brechas de privacidad como eventos de continuidad?

- ☐ A) El BCP trata las brechas de privacidad como incidentes de seguridad, sin análisis específico del impacto operativo que puede derivarse de una suspensión regulatoria como la ordenada por la AEPD en el caso AENA.
- ☐ B) El BCP menciona las brechas de datos pero sin análisis de impacto en negocio (BIA) específico para escenarios de suspensión regulatoria o litigios masivos por privacidad.
- ☐ C) BCP con escenarios de brecha de datos como evento de continuidad, incluyendo protocolo de comunicación con la AEPD, gestión de la comunicación externa y estimación del impacto reputacional.
- ☐ D) BCP integrado con el programa de privacidad: escenarios de suspensión regulatoria, litigios de clase, acciones de grupos de afectados; con RTO y RPO definidos para sistemas que tratan datos personales críticos.
- ☐ E) Privacy-integrated resilience: el BIA incluye valoración económica del riesgo de privacidad (coste de brechas, sanciones, litigios, daño reputacional), con análisis actuarial y cobertura de ciberseguro que incluye responsabilidad por privacidad.

P10.4 — Zero Trust y privacidad por diseño en arquitectura

¿Ha integrado su organización principios de Zero Trust Architecture en su diseño de sistemas con implicaciones para los indicadores LINDDUN?

- ☐ A) Zero Trust es un concepto de marketing que nuestro proveedor de firewall menciona en sus presentaciones.
- ☐ B) Estamos en proceso de adopción de Zero Trust pero sin análisis explícito de su impacto en los indicadores LINDDUN (la paradoja del log, la microsegmentación como control de Linking, etc.).
- ☐ C) Arquitectura Zero Trust en implantación, con consideración de los principios de verificación explícita y mínimo privilegio como controles de los indicadores Data Disclosure e Identifying.
- ☐ D) Zero Trust operativo con análisis de la tensión entre trazabilidad de seguridad (Non-repudiation positivo) y privacidad de usuarios (Non-repudiation negativo), con política documentada de gestión de logs que equilibra ambos requisitos.
- ☐ E) Privacy-enhanced Zero Trust: verificación continua con anonimización de logs, microsegmentación que actúa como control de Linking, DNSSec + DoH para protección de metadatos, y análisis LINDDUN MAESTRO de toda la arquitectura.

SECCIÓN FINAL — PREGUNTAS ABIERTAS Y VALORACIÓN

PF.1 — Principales obstáculos

En su opinión, ¿cuáles son los tres principales obstáculos que impiden a su organización alcanzar un mayor nivel de madurez en privacidad?

(Respuesta abierta — máximo 300 palabras)

PF.2 — Inversiones prioritarias

Si dispusiera de presupuesto adicional para privacidad en 2026, ¿en qué lo invertiría prioritariamente?

- ☐ Formación y cultura de privacidad
- ☐ Herramientas de automatización (LINDDUN, EIPDs, gestión de derechos)
- ☐ Consultoría y refuerzo del equipo DPO
- ☐ Tecnologías de mejora de privacidad (PETs: anonimización, cifrado, federación)
- ☐ Actualización de sistemas heredados con Privacy by Design
- ☐ Certificaciones (ISO 27701, ENS, sello de privacidad)
- ☐ Evaluación y respuesta a riesgos de IA

PF.3 — Valoración del marco LINDDUN/LIINE4DU

Habiendo completado esta encuesta, ¿cuál es su valoración de la utilidad del marco LINDDUN/LIINE4DU para su organización?

- ☐ Muy útil: proporciona una estructura sistemática que necesitábamos
- ☐ Útil: complementa los marcos que ya usamos (ISO 27001, RGPD directo)
- ☐ Neutro: no estamos seguros de cómo integrarlo en nuestra práctica actual
- ☐ Poco útil: demasiado técnico o complejo para nuestra organización
- ☐ No útil: nuestras necesidades están cubiertas con los marcos actuales

PF.4 — Disposición a participar en el benchmarking sectorial

¿Estaría su organización dispuesta a compartir los resultados anonimizados de esta encuesta para la elaboración de un benchmarking sectorial de madurez en privacidad?

- ☐ Sí, con total apertura
- ☐ Sí, siempre que los datos estén completamente anonimizados
- ☐ Solo si podemos revisar el informe final antes de su publicación
- ☐ No, preferimos mantener la confidencialidad de nuestra posición

ANEXO: ESCALA DE PUNTUACIÓN IGM

Nivel	Descripción	Puntuación por ítem
A	Inexistente / Ad hoc	1
B	Inicial / Reactivo	2
C	Definido / Documentado	3
D	Gestionado / Medido	4
E	Optimizado / Continuo	5

Índice de Madurez Global (IGM) = Suma ponderada de puntuaciones / Número total de ítems puntuables

Escala IGM:

- 1.0 – 1.9: Madurez muy baja (riesgo regulatorio inmediato)
- 2.0 – 2.9: Madurez baja (cumplimiento formal insuficiente)
- 3.0 – 3.9: Madurez media (cumplimiento básico, mejoras necesarias)

- 4.0 – 4.4: Madurez alta (buenas prácticas implementadas)

- 4.5 – 5.0: Madurez muy alta (excelencia en privacidad)

Encuesta elaborada conforme al marco LINDDUN (KU Leuven, DistriNet), LIINE4DU 1.0 (AEPD, 2024), RGPD, AI Act y ENISA Threat Landscape 2025. Versión 1.0 — Abril 2026.